

Empowering the Underdog: A Scalable Cybersecurity Model for SMBs

Grace Petty

IT497 Capstone

Dr. Connie White

July 20, 2025

Introduction

Small-to-mid-sized businesses (SMBs) are on the frontlines of modern cyberattacks, yet many lack the tools, staffing, and knowledge to remain resilient in modern cyberspace. In the past, the belief was that SMBs were too small to be noticed by cybercriminals. Now they are viewed as easy, high-value targets. According to Verizon (2025), more than 90% of breached organizations were SMBs with fewer than 1,000 employees. Many SMBs are misled into believing that outsourcing security absolves them of internal responsibility. In 2024, IBM identified the top three factors that amplified breach costs: security system complexity, a shortage of skilled internal personnel, and third-party breaches. Resilience cannot be outsourced, and complexity only compounds vulnerability. Without a model that addresses both technology and human response, SMBs will continue to be the easiest target in cyberspace. However, SMBs can punch above their weight in the face of growing cybersecurity threats by adopting a tailored hybrid framework that fuses scalable technical controls with targeted internal training, a necessary strategy as attackers increasingly exploit SMB vulnerabilities and response delays.

Why SMBs Remain Vulnerable Despite Available Resources

There remains a persistent belief that SMBs can fly under the radar of cybercriminals due to the size of their operations. Yet Verizon (2025) reports SMBs make up over 90% of breaches, and while ransomware is involved in 39% of all breaches, it appears in a staggering 88% of SMB-related breaches. SMBs are not only vulnerable, but they are treated as primary targets. The high-profile ransomware attack on Colonial Pipeline, while not an SMB, illustrates that breaches often stem from basic oversights. Attackers exploited a deprecated VPN lacking multifactor authentication (MFA), shutting down critical fuel distribution across the East Coast of the United States (DOJ, 2021). This was not a sophisticated zero-day, the attackers found a

single point of compromise on a preventable vulnerability and executed. A single internal weakness can nullify even the most advanced external defense.

As digital relevance expands, an internet presence is necessary for revenue and visibility, extending the SMB attack surface. Threat actors now use automation to routinely scan for misconfigured systems, unpatched software, and weak authentication, conditions commonly found in under-resourced SMB environments. The FBI San Francisco Division (2024) warned about the growing use of AI tools to conduct sophisticated phishing/social engineering attacks and voice/video cloning scams. Poremba (2025) adds that emerging technologies like generative AI and quantum computing are accelerating the evolution of threats beyond what isolated security teams can manage. This growing complexity demands a security culture embedded and driven by functional leadership, not only IT personnel.

SMBs' overreliance on third-party vendors creates a critical vulnerability that is often overlooked. A lack of IT personnel, budget constraints, and technical knowledge often pushes them to outsource their cybersecurity entirely. While NIST guidelines support partially outsourcing functions such as 24/7 monitoring of intrusion detection systems or firewalls to a Managed Security Service Provider (MSSP) (Grance, Kent, & Kim, 2012), it does not absolve the SMB from internal responsibility. Organizations must retain responsibility for incident response coordination and decision-making capabilities. Even high-profile vendors are not immune to compromise or outages. In July 2024, CrowdStrike caused a massive global IT disruption affecting over 8.5 million systems, grounding Delta Air Lines and disrupting 1.3 million travelers (Tufin, 2025). If major vendors can trigger that level of disruption, SMBs relying solely on external support without supportive internal safeguards are even more exposed.

Outsourcing cannot be the only strategy. If an SMB does not know what it is defending or what it is protecting it from, no vendor or platform can solve the underlying risk.

While NIST and the SANS provide security frameworks aligned with federal standards, they are often too granular or abstract for SMBs to implement without expert guidance. Most lack dedicated IT personnel and struggle to apply even basic framework components. Therefore, it is unrealistic and arguably naive to expect them to locate, interpret, and extract the relevant and actionable steps from broad and dispersed documentation by themselves. The NIST SP 800-37 (2018) Risk Management Framework (RMF) outlines a comprehensive seven-step process, but assumes a level of expertise most SMBs lack. Similarly, the NIST Cybersecurity Framework (CSF) 2.0 Framework is self-described as non-prescriptive and flexible, while valuable in theory, not directly actionable without interpretation. Most SMBs need a streamlined, practical approach focused on immediate vulnerabilities, not complex frameworks and hundreds of pages of guidance.

Scalable Technical Controls

Foundational Controls

SMBs must prioritize foundational defensive measures to build a security baseline that supports compliance and resilience. The first step is establishing visibility into the systems, assets, and users. The NIST SP 1314 (2024) QuickStart Guide for SMBs emphasizes maintaining an up-to-date asset inventory, ensuring routine data backups, and implementing MFA wherever possible. Visibility begins by defining what digital assets, endpoints, and user accounts the organization owns or manages. Once exposure is mapped, SMBs can apply simple, high-impact controls to reduce risk immediately.

MFA thwarts 99% of credential-based attacks (Cybersecurity and Infrastructure Security Agency [CISA], n.d.). Regular, automated local and cloud-based data backups and periodic testing ensure business continuity during ransomware attacks, hardware failure, or system compromise. Enforcing strong passwords, using a vetted password manager, and automatic password updates help defend against credential stuffing and brute-force attacks. SMBs also must change default login credentials for all network hardware and applications. A 2024 survey by Broadband Genie found that 86% of respondents have never changed their router's admin password, and 52% had never modified factory settings, leaving systems vulnerable to default exploits (Tofts, 2025).

Operational Controls

With foundational controls in place, SMB's can focus on daily safeguards that close gaps for known and preventable vulnerabilities. These include automated software patching, properly configured firewalls, and endpoint monitoring. Verizon (2025) reports that 70% of espionage-motivated breaches leveraged vulnerability exploitation as the initial access vector, showcasing the risk of running unpatched services. Yet many SMBs delay updates due to a lack of internal staff, routine, or fear of a disruption in productivity, to which each delay extends the attack window. Automated patching and setting firewalls to "default deny" for inbound/outbound traffic can drastically reduce exposure for minimal cost.

CIS Controls v8 (2023) includes these measures in its Implementation Group 1 for small enterprises. Similarly, PCI DSS v4.0 (2022) requires regular patching, logging, secure configurations, and replacing default credentials to protect cardholder data (PCI Security Standards Council, 2022).

With daily safeguards automated and basic defenses established, SMBs can advance to broader, long-term strategic controls that limit and contain the impact of future incidents.

Strategic Controls

Long-term resilience for SMBS depends on strategic risk management. The first step is data classification, which is knowing what data they hold, who can access it, and how sensitive it is. PCI DSS will govern payment data, and European user data may trigger GDPR. Without proper classification, SMBs are haphazardly harboring data that may be improperly stored or accessible. The NIST IR 8496 (2023) offers a simple model for data categorization by confidentiality, integrity, and availability (CIA). The classification can remain simple, prioritizing data as low, medium, or high risk to help clarify and prioritize evolving protection efforts.

With data classified, network segmentation can isolate high-value data and systems from the broader network. Segmentation will slow attacker movement if a breach occurs, reducing the impact. Without it, the attacker can access everything from a single foothold. SMBs need to implement VLANs or subnets by data sensitivity or role to contain threats and protect critical assets and systems.

For sensitive or regulated data, encryption should be enabled at rest on storage systems harboring customer, financial, or proprietary information. Most modern platforms support this with minimal configuration. While encryption does not block unauthorized access directly, it limits the exposure of compromised data.

For SMBs to respond quickly to a compromise, they must have an incident response (IR) plan that defines roles, communication procedures, and decision points. Internal staff are often the first to detect issues and must know how to isolate the threat, who to notify, and how to

execute the IR plan. The NIST SP 1314 (2024) encourages cross-team cohesiveness by integrating IR planning into its SMB QuickStart guide, emphasizing simplicity over complexity. Strategic controls like classification, segmentation, encryption, and IR planning equip SMBs to contain threats, respond efficiently, and preserve business continuity. None require a large security team or are cost-prohibitive. They rely on clarity, accountability, and strategic coordination.

Internal Training and Human Responsibility

Building a Culture of Responsibility

Even with strong technical controls in place, they are not enough to secure an organization. The most vulnerable element remains the human. Verizon (2025) found that 60% of data breaches are due to human involvement. Whether due to carelessness, lack of awareness, or being overburdened, individuals consistently represent the biggest liability in an organization's defenses.

Ironically, these same individuals are also the first to detect anomalies, such as sluggish system performance, questionable emails, or suspicious login activity. They are the most vulnerable to phishing and social engineering, but also best positioned to stop it. Everyone associated with the SMB, including leadership, employees, contractors, and vendors, is responsible for organizational security.

Despite this, most organizations underinvest in human-focused defense. Carpenter and Roer (2022) report that less than 3% of security spending is focused on the human layer (ch 2, para. 18). These errors are rarely malicious and most arise from a lack of understanding or practical training. People often do not know what to look for or what to do if they see it.

Building a strong security culture means empowering people with knowledge, tools, and motivation. This is not about making every team member a cybersecurity expert, but about helping them develop awareness of risk, responsibility, and healthy digital habits. Leadership must drive this shift through both policy and example. Training must be consistent, role-based, and job-relevant, focused on helping people recognize red flags and how to respond.

Cybersecurity cannot be treated as a box to be checked, it has to become part of the organization's identity.

Training for Practical Resilience

Fixing the human element requires consistent, repeatable, role-specific training that is clear, relevant, and easy to apply. People must understand what is being presented, apply it with minimal friction, and directly tie it to the current threat landscape.

A front desk employee should recognize phishing emails, social engineering attempts, and signs of a workstation compromise. A subcontractor does not have to memorize every compliance factor, but must know how to access and handle sensitive data securely. All users need to know what risk looks like, why it matters, what a potential breach looks like, and who to contact. This is especially significant as email threats evolve. KnowBe4 (2025) reported a 47% increase in phishing emails that successfully bypass Microsoft's native security and secure email gateways, and confirms that 82.6% of phishing emails use AI.

Targeted training is the most effective way to influence and change security culture and behavior. IBM (2024) found employee training reduced breach costs by \$258,629 on average, making it the top cost-reduction factor across all measured controls. Options for training include bite-sized, gamified modules, many of which are free or low-cost through CanIPhish (n.d.) or [phished.io](#) (n.d.), for example, are available to SMBs and can be developed with minimal effort

to teach recognition and response skills by creating muscle memory rather than passive absorption. This approach is reinforced by the CISA Cyber Essentials ToolKit (2021) and the NIST SP 800-61r3 (2025), which recommend cyber hygiene tips in meetings, assigning a monthly short video, and a phishing simulation per quarter. These steps are simple, repeatable, cost-effective, and do not require a certified professional. Security training should never feel like a punishment. It must feel valuable, engaging, and concise, so people want to do it, identify with it, and it becomes part of their mindset and the organization's identity.

Implementation

The S3 Framework: A Hybrid Model for SMB Resilience

The S3 Framework is how SMBs close the gap between cybersecurity policy and practice. It's a three-phased, actionable model designed to give SMBs a realistic path toward greater security, without requiring a security team or budget overhaul.

The S3 Framework breaks down to:

- **Secure:** Implement basic technical controls that address the highest statistical risk vulnerabilities (eg. MFA, asset inventory, data backups, patching, firewall, segmentation, and antivirus).
- **Simulate:** Behavior-based training to address human error through phishing simulations, targeted awareness training, and simple response drills.
- **Sustain:** Build repeatable habits, evaluations, and lightweight monitoring without reliance on expensive tools, vendors, or dedicated IT personnel.

The purpose of the S3 Framework is to eliminate the knowledge and resource barrier that prevents many SMBs from achieving cybersecurity maturity. It is not a certification program or a compliance checklist. It is an execution-ready roadmap with which an SMB can do something

immediately. SMB can implement it using existing personnel and affordable, often built-in tools, reducing risk in days, not quarters.

Applying the S3 Framework

Consider a 15-person e-commerce business that uses Microsoft Products, Google Workspace, QuickBooks, a basic wireless router, and remote access capabilities for senior leadership. There are no internal IT personnel, just an active owner and a senior manager who manages onboarding and vendors.

Phase 1: Secure

In the first week, the owner completes a device and software inventory in a shared spreadsheet, enables MFA on all admin accounts (e.g. Google, QuickBooks), sets up automated cloud backups (e.g. Google Vault, OneDrive), removes default router credentials, configures the local firewall to “explicit deny” for all inbound traffic, installs an antivirus on all endpoints, and schedule weekly software updates on all endpoints. Most of these tasks are completed using built-in tools and take less than a day of focused effort. The result is an immediate reduction in exposure to credential theft, ransomware, and misconfiguration.

Phase 2: Simulate

By week two, or at least by month two, the owner will designate one staff member as the security lead. This person shares a five-minute phishing/social engineering awareness video in a team meeting, runs a free or low-cost phishing simulation (e.g., CanIPhish or phished.io), and distributes a one-page “If Something Looks Suspicious, Follow These Steps” checklist. Cybersecurity becomes part of monthly check-ins, with one question or scenario discussed.

Phase 3: Sustain

The Sustain phase begins by week three or month three. In this phase, a one-page incident response plan is created, naming roles and responsibilities. Internal data is classified into low, medium, and high-risk categories. Basic network segmentation is introduced using VLANs, specific guest access, or user groups within Microsoft 365 or Google Workspace. Monthly login review alerts are enabled to flag unusual access, and phishing simulations and IR refreshers are scheduled quarterly.

Using the S3 framework, this business transitions from a highly vulnerable target to a measurably resilient one without external consultants, a large budget, or formal IT personnel. Their risk from the top breach vectors, as identified by IBM and Verizon, phishing, credential compromise, unpatched systems, and human error, have all been addressed.

Conclusion

Cybersecurity resilience stems from execution, not size. SMBs that adopt a hybrid approach of scalable technical controls and internal accountability can consistently outperform their peers in breach prevention and recovery efforts. The S3 Framework offers a direct, actionable path for SMBs to build this resilience using what they already have. It does not require extensive technology knowledge, contracted consultants, or enterprise budgets. Instead, it focuses on high-impact safeguards, user awareness, and simple, repeatable habits. Effective cybersecurity should not be reserved for major players. It must be achievable and effective at all levels. With a focused plan, basic tools, and internal ownership, any SMB can protect its data, operations, and personnel from today's most common security threats. It doesn't need to be complicated. It simply needs to be done.

Reference List

CanIPhish. (n.d.). *Free phishing simulations & cybersecurity awareness training*.

<https://caniphish.com/>

Carpenter, P., & Roer, K. (2022). *The security culture playbook: An executive guide to reducing risk and developing your human defense layer*. Wiley.

Center for Internet Security. (2023). *CIS controls v8: Implementation guide*.

<https://learn.cisecurity.org/CIS-Controls-v8-guide-pdf>

Cybersecurity and Infrastructure Security Agency. (2021). **Cyber essentials starter kit**. U.S. Department of Homeland Security.

https://www.cisa.gov/sites/default/files/publications/Cyber%20Essentials%20Starter%20Kit_03.12.2021_508_0.pdf

Cybersecurity & Infrastructure Security Agency (CISA). (n.d.). **Multi-factor authentication**.

U.S. Department of Homeland Security. <https://www.cisa.gov/resources-tools/services/multi-factor-authentication>

IBM Security. (2024). **Cost of a data breach report 2024**. IBM.

<https://www.ibm.com/reports/data-breach>

Federal Bureau of Investigation. (2024, February 7). *FBI warns of increasing threat of cyber criminals utilizing artificial intelligence*. FBI San Francisco.

<https://www.fbi.gov/contact-us/field-offices/sanfrancisco/news/fbi-warns-of-increasing-threat-of-cyber-criminals-utilizing-artificial-intelligence>

KnowBe4. (2025). *Phishing threat trends: 2025 benchmark report*.

https://www.knowbe4.com/hubfs/Phishing-Threat-Trends-2025_Report.pdf

Mittal, M. (2024, December). Colonial pipeline cyberattack drives urgent reforms in cybersecurity and critical infrastructure resilience. *Open Journal of Civil Engineering, 12*(5), Article 11. <https://doi.org/10.11648/j.ogce.20241205.11>

National Institute of Standards and Technology. (2018). *Risk management framework for information systems and organizations: A system life cycle approach for security and privacy* (NIST SP 800 37 Rev. 2).

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-37r2.pdf>

National Institute of Standards and Technology. (2023). *NIST interagency report 8496: Data classification practices: Facilitating data-centric security* (NIST IR 8496).

<https://doi.org/10.6028/NIST.IR.8496>

National Institute of Standards and Technology. (2024). *NIST risk management framework (RMF) small enterprise quick start guide* (NIST SP 1314).

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1314.pdf>

PCI Security Standards Council. (2022). *PCI DSS v4.0 quick reference guide*. Payment Card Industry Security Standards Council. https://docs-prv.pcisecuritystandards.org/PCI%20DSS/Supporting%20Document/PCI-DSS-v4__X-ORG.pdf

Phished. (n.d.). *Automated cybersecurity awareness training & phishing simulations.*

<https://phished.io/>

Poremba, S. (2025, January 9). *Cybersecurity trends: IBM predictions for 2025*. IBM Think.

Retrieved June 24, 2025, from <https://www.ibm.com/think/insights/cybersecurity-trends-ibm-predictions-2025>

Tofts, A. (2025, April 7). *Router security research*. Broadband.co.uk.

<https://www.broadband.co.uk/broadband/help/router-security-research>

Tufin. (2024, July 4). *The lasting impact of the CrowdStrike update outage*.

<https://www.tufin.com/blog/lasting-impact-of-crowdstrike-update-outage>

U.S. Department of Justice. (2021, June 7). *Department of Justice seizes \$2.3 million in cryptocurrency paid to ransomware extortionists, DarkSide*.

<https://www.justice.gov/archives/opa/pr/departments-justice-seizes-23-million-cryptocurrency-paid-ransomware-extortionists-darkside>

Verizon. (2025). *2025 data breach investigations report: Infographic*.

<https://www.verizon.com/business/resources/infographics/2025-dbir-infographic.pdf>